Confidentiality Concerns -- Guided Notes ANSWER KEY

Unit tp-6.1 | CompTIA Network+ N10-009 Obj. FC0-U71 6.1 | N10-008 FC0-U71 6.1

For instructor use / distribute after students complete the notes.

Question 1

The CIA triad stands for _______, _______, and _______. These are the three core principles of information security. _______ means that data can only be accessed by authorized individuals. _______ means data is accurate and has not been changed. _______ means systems and data are accessible when needed.

Answer: Confidentiality, Integrity, Availability; Confidentiality; Integrity; Availability.

Question 2

Confidentiality means preventing _______ access to information. Threats to confidentiality include _______ (stealing data over a network), _______ (tricking users into revealing credentials), and _______ (collecting discarded documents with sensitive info). The primary countermeasure for confidentiality is _______.

Answer: Unauthorized; eavesdropping (sniffing); phishing; dumpster diving; encryption.

Question 3

Encryption protects confidentiality by converting _______ text into _______ text using an algorithm and key. _______ encryption uses the same key to encrypt and decrypt. _______ encryption uses a public key to encrypt and a private key to decrypt. HTTPS uses _______ to secure web communications.

Answer: Plain (clear); cipher; symmetric; asymmetric; TLS (SSL/TLS).

Question 4

Access control protects confidentiality by restricting _______ to only what each user is authorized to see. _______ access control (MAC) uses security labels set by the system. _______ access control (DAC) lets the resource owner set permissions. _______ access control (RBAC) assigns permissions based on job role.

Answer: Access; mandatory; discretionary; role-based.

Question 5

Data classification helps protect confidentiality by labeling data so appropriate _______ controls are applied. Data labeled _______ or _______ should be accessible only to specific authorized individuals. Sensitive data should be _______ in transit (over networks) and _______ at rest (stored on drives).

Answer: Security; confidential; restricted (top secret); encrypted; encrypted.

Question 6

A _______ (VPN) protects confidentiality over public networks by creating an encrypted _______ between the user and the organization. Without a VPN, data sent over public Wi-Fi can be intercepted by _______ attacks where an attacker positions themselves between sender and receiver.

Answer: Virtual Private Network; tunnel; man-in-the-middle (MITM).

Question 7

The _______ of least privilege states that users and systems should have only the minimum access required for their job. Applying this principle limits _______ damage if credentials are compromised. Over-permissioned accounts are a major source of _______ violations in real breaches.

Answer: Principle; blast radius (damage); confidentiality.

Question 8 -- Real World Application

REAL WORLD: A healthcare company stores patient records in an unencrypted database. A laptop belonging to an IT employee is stolen from a car. The laptop had a local copy of the database for testing. No patient data is encrypted at rest. Explain what confidentiality failure occurred and describe two controls that would have prevented data exposure.

Answer: Confidentiality failure: sensitive data (PHI -- protected health information) was stored in plaintext on an endpoint (the laptop). When the physical device was stolen, the attacker gained immediate access to all patient records with no technical barrier. This is both a HIPAA violation and a confidentiality failure because unauthorized individuals (thieves) can now read the data. Control 1 -- Full disk encryption: enable BitLocker (Windows) or FileVault (macOS) on all endpoint devices. If the laptop had been encrypted, the thief cannot read any data without the decryption key -- the stolen hardware is useless for data access. Control 2 -- No production/PHI data on development endpoints: implement a policy prohibiting copying real patient data to local machines for testing. Use synthetic (fake but realistic) test data. Any exception requires approval, and data must be deleted when testing is complete. This eliminates the exposure vector entirely.